

Guía Técnica Seguridad de la información y Ciberseguridad

Introducción

La presente guía técnica tiene por finalidad desarrollar los aspectos operativos y procedimentales necesarios para la correcta implementación de la [Norma Técnica de Seguridad de la Información y Ciberseguridad establecida por el Decreto N° 7, de 2023](#) .

Esta guía no crea obligaciones adicionales para los órganos de la Administración del Estado. Sin perjuicio de lo anterior, la Norma Técnica de Seguridad de la Información y Ciberseguridad sí mandata regular los siguientes aspectos en esta guía técnica, los cuales se entienden integrados a dicha Norma:

- i) El Contenido mínimo del diagnóstico inicial, que deberá realizar cada órgano de la Administración del Estado para evaluar su estado de ciberseguridad (artículo 4).
- ii) Contenido y desarrollo de la Política de Seguridad de la Información y Ciberseguridad (artículo 5).
- iii) Especificar las funciones y categorías que deben atender los órganos de la administración del Estado para la generación e implementación de la política (artículo 6).

Sin perjuicio de lo establecido en esta guía, los órganos de la Administración del Estado también deberán atender a las instrucciones y lineamientos que realice la Agencia Nacional de Ciberseguridad, de conformidad con la ley N° 21.663 marco de ciberseguridad.

Diagnóstico Inicial

Para la elaboración de su Política de Seguridad de la Información y Ciberseguridad, cada órgano de la Administración del Estado deberá realizar un diagnóstico inicial del estado de su ciberseguridad, conforme a lo dispuesto en la Norma Técnica. Este diagnóstico constituye la base para definir prioridades, medidas y objetivos institucionales en la materia, considerando los tres pilares de la ciberseguridad: personas, procesos y tecnología.

Para su desarrollo, se sugiere considerar, al menos, las siguientes actividades:

1. Personas
2. Análisis de capacidades y recursos humanos: identificar la disponibilidad, competencias y roles del personal involucrado en la gestión de la seguridad de la información y ciberseguridad, considerando tanto equipos especializados como funcionarios que, por sus funciones, acceden o administran sistemas e información relevante.

3. Concientización y capacitación: evaluar el nivel de conocimiento y sensibilización de las personas respecto de buenas prácticas de seguridad de la información y ciberseguridad, así como la existencia de programas de capacitación, inducción o formación continua en estas materias.
4. Procesos
5. Revisión del ordenamiento institucional y la gobernanza: analizar la existencia y claridad de los procesos internos asociados a la gestión de la seguridad de la información y ciberseguridad, incluyendo la definición de roles, responsabilidades, instancias de coordinación, flujos de reporte y mecanismos de toma de decisiones.
6. Evaluación de procesos operativos y de gestión: identificar la existencia, formalización y nivel de aplicación de procesos tales como gestión de activos de información, gestión de riesgos, control de accesos, continuidad operativa, gestión de incidentes y relación con proveedores, detectando brechas y oportunidades de mejora.
7. Tecnología
8. Identificación de activos críticos: identificar las plataformas electrónicas, sistemas, aplicaciones, bases de datos, redes y servicios digitales relevantes para la operación institucional, así como los procesos y funciones institucionales que los utilizan, determinando aquellos activos cuya afectación pueda comprometer la continuidad, integridad o disponibilidad de los servicios del órgano.
9. Evaluación de vulnerabilidades y amenazas: identificar las principales vulnerabilidades técnicas, organizacionales y humanas asociadas a los activos críticos, tales como configuraciones deficientes, parches pendientes, accesos no controlados, dependencia de personas clave, falta de segregación de funciones y debilidades de los procesos operativos.
10. Revisión del estado de los controles existentes: verificar la existencia, formalización y efectividad de los controles implementados por el órgano en materia de protección de la información, gestión de accesos, respaldo, continuidad operativa, monitoreo y mecanismos de respuesta a incidentes, considerando su integración con los procesos institucionales y los roles definidos, e identificando brechas y áreas de mejora.
11. Análisis básico de riesgos: evaluar la probabilidad e impacto de los riesgos identificados, considerando de manera conjunta factores humanos, organizacionales y tecnológicos, con el fin de priorizar las necesidades detectadas y orientar las medidas que deberán incorporarse en la Política de Seguridad de la Información y Ciberseguridad.

Para apoyar este proceso, se recomienda que los órganos, cuando sus recursos lo permitan, recurran a asesorías externas especializadas, evaluaciones organizacionales, pruebas de intrusión (hackeo ético) y/o ejercicios de levantamiento interno de información mediante matrices u otros instrumentos aplicados a las divisiones, departamentos o unidades pertinentes.

El resultado del diagnóstico deberá sintetizar el nivel de madurez institucional del órgano en materia de seguridad de la información y ciberseguridad, considerando los ámbitos de personas, procesos y tecnología, y servirá de fundamento para la definición de los objetivos, metas y acciones de su Política.

El diagnóstico inicial deberá realizarse al menos con ocasión de la elaboración de la Política de Seguridad de la Información y Ciberseguridad, y deberá ser revisado y actualizado cuando corresponda, especialmente cuando se produzcan cambios relevantes en las personas, procesos o plataformas electrónicas del órgano,

tales como la incorporación de nuevos sistemas críticos, modificaciones organizacionales significativas o la ocurrencia de incidentes de seguridad de la información o ciberseguridad de impacto relevante. Sin perjuicio de lo anterior, se recomienda que los órganos de la Administración del Estado revisen integralmente su diagnóstico de seguridad de la información y ciberseguridad, al menos, cada dos años, con el objeto de asegurar que el diagnóstico refleje adecuadamente la evolución de los riesgos, de las capacidades institucionales y del contexto tecnológico en que opera el órgano.

Política de Seguridad de la Información y Ciberseguridad

Cada órgano de la Administración del Estado deberá elaborar una Política de Seguridad de la Información y Ciberseguridad, la cual deberá ser aprobada mediante acto administrativo por su Jefe Superior de Servicio.

Esta Política tendrá como objetivo establecer las directrices generales en materia de seguridad de la información y ciberseguridad dentro del órgano, velar por la seguridad de los componentes de software, hardware y sistemas informáticos, así como de los datos que almacenan, procesan e interoperan, y definir la visión estratégica del OAE en estas materias junto con los lineamientos para alcanzar los objetivos propuestos.

En cumplimiento del Artículo 5 de la Norma Técnica, la Política deberá incluir, al menos:

1. Sus objetivos generales y específicos;
2. La definición de su alcance y la identificación de los activos y activos de información que deben protegerse;
3. La legislación y normativa vigente aplicable;
4. La determinación de roles y responsabilidades, incluyendo la designación de un(a) responsable institucional de seguridad de la información y ciberseguridad y un(a) responsable de los activos de información.

Para la generación e implementación de la política deberán atenderse las funciones y categorías que se desarrollarán más adelante y a que se refiere la Norma Técnica en su artículo 6°.

3.1 Objetivo general y objetivo específicos

Este apartado permite explicitar la orientación estratégica del órgano en materia de seguridad de la información y ciberseguridad.

En términos generales, la Política debe contener un objetivo general, que exprese la finalidad institucional de resguardar la confidencialidad, integridad, disponibilidad y resiliencia de la información, así como de los sistemas y plataformas tecnológicas que la soportan.

Asimismo, se recomienda incluir objetivos específicos que permitan operacionalizar dicha finalidad, tales

como:

- ▶ Establecer un marco institucional de gobernanza, que determine el alcance, los roles y las responsabilidades, asegurando una adecuada segregación de funciones y mecanismos de coordinación.
- ▶ Incorporar la seguridad desde el diseño en todos los proyectos del órgano.
- ▶ Resguardar la confidencialidad, integridad y disponibilidad de la información, mediante la operación de infraestructuras tecnológicas seguras, resilientes y confiables.

La inclusión de estos elementos facilita que la Política represente la visión institucional del órgano, permita priorizar medidas y oriente los controles, protocolos y planes que se deriven de ella.

3.2. Identificación y determinación del alcance de la Política

El alcance permite precisar a quiénes aplica la Política y qué elementos quedan cubiertos por ella. Definirlo de manera clara facilita su aplicación práctica y reduce ambigüedades sobre responsabilidades internas.

Para efectos de la elaboración de la Política, se recomienda que los OAEs distingan claramente entre:

- a) Alcance subjetivo (a quiénes aplica la Política): se recomienda señalar los grupos de personas comprendidos, tales como funcionarios, equipos internos y terceros que, por sus funciones o contratos, acceden a información o sistemas del órgano.
- b) Alcance objetivo (qué elementos, sistemas o activos quedan cubiertos): se recomienda precisar los activos y activos de información protegidos, las plataformas electrónicas y sistemas que sustentan procedimientos administrativos, así como la infraestructura tecnológica asociada.

3.3. Diagnóstico Inicial

Para elaborar la Política, se recomienda que cada OAE incluya una síntesis del diagnóstico inicial que exige la Norma Técnica, ya que constituye el fundamento para definir medidas y objetivos en la Política.

Dicha síntesis deberá mantenerse actualizada, debiendo revisarse cada vez que la Política sea modificada o actualizada, o cuando se produzcan cambios relevantes en los procesos, personas o plataformas electrónicas del órgano, tales como la incorporación de nuevos sistemas críticos, cambios significativos en la organización o la ocurrencia de incidentes de seguridad de la información o ciberseguridad de impacto relevante.

3.4 Indicación de la legislación y normas específicas y vigente que resulten aplicables

La Política debe referirse al marco jurídico y técnico que condiciona su elaboración e implementación. Esto orienta a los equipos internos sobre las obligaciones legales aplicables y alinea la Política con los estándares vigentes.

Los OAEs pueden incorporar, entre otras, las siguientes referencias:

- ▶ Ley N° 21.180 y su Reglamento (DS N° 4/2020), que regulan la digitalización de los procedimientos

administrativos;

- ▶ Decreto Supremo N° 7/2023, que establece la Norma Técnica de Seguridad de la Información y Ciberseguridad;
- ▶ Ley N° 19.628, y, cuando corresponda, la Ley N° 21.719, relativa a la protección de datos personales;
- ▶ Ley N° 21.663, Marco de Ciberseguridad, cuando el órgano tenga obligaciones vinculadas;

normas internas del propio órgano o del sector institucional respectivo.

3.5. Especificación de los roles institucionales y definición de responsabilidades

La Política debe definir la estructura de gobernanza en materia de seguridad. Se deberán establecer los roles del responsable institucional de seguridad de la información y ciberseguridad, y del responsable de los activos de información.

Responsable institucional de seguridad de la información y ciberseguridad

Será el encargado de velar por la seguridad de la información y ciberseguridad en el OAE respectivo, además de asegurar el desarrollo, cumplimiento y actualización de la Política y de gestionar la administración de la seguridad de la información y ciberseguridad.

Responsable de los activos de información

Deberá realizar la identificación, clasificación de los activos de información, y gestionar el riesgo y niveles de seguridad asociados.

Cada órgano de la Administración del Estado deberá determinar si el rol de responsable institucional de seguridad de la información, y el de responsable de los activos de información se unifican o no en una sola persona.

Con todo, es preferible que éstos roles dependan directamente del Jefe de Servicio, ya que cumplirán funciones de auditoría y entrega de directrices en todos las materias referentes a seguridad de la información y ciberseguridad del OAE, tanto a las áreas de tecnología como al resto del órgano.

El desempeño de estas funciones no podrá ser externalizado bajo ninguna forma.

3.6 Funciones y categorías

La Norma Técnica estructura la gestión de la seguridad de la información y la ciberseguridad en cinco funciones. Cada función agrupa un conjunto de categorías, que permiten a los Órganos de la Administración del Estado ordenar sus capacidades, identificar brechas y planificar mejoras. Estas funciones son:

1. **Identificación:** cómo conoce su entorno, activos, riesgos y relación con proveedores.
2. **Protección:** cómo resguarda sus activos, datos, accesos y redes, incorporando además la capacitación como medida preventiva.

3. **Detección:** cómo identifica eventos anómalos o indicios de incidentes, a través de monitoreo y análisis.
4. **Respuesta:** cómo actúa frente a incidentes, incluyendo comunicación interna y externa, y medidas de mitigación.
5. **Recuperación:** cómo restablece servicios y capacidades tras un incidente, incluyendo continuidad operativa y mejoras posteriores.

Las funciones y categorías definidas en la Norma Técnica constituyen el marco estructurante que todo OAE debe considerar al elaborar su Política de Seguridad de la Información y Ciberseguridad. Sin embargo, no se exige que cada función y categoría se encuentre completamente desarrollada en la primera versión de la Política.

La Política tiene por objeto establecer lineamientos generales y compromisos institucionales, mientras que el desarrollo detallado de los procesos, controles, indicadores y roles asociados a cada categoría podrá postergarse y abordarse gradualmente mediante documentos complementarios, tales como protocolos, procedimientos, instructivos o planes específicos.

De este modo, aunque las funciones abarcan un conjunto amplio de categorías —lo que podría resultar complejo para algunos órganos—, los OAE pueden comenzar con una Política acotada y orientadora, e ir profundizando en cada categoría conforme a su nivel de madurez, recursos disponibles y los resultados del análisis de riesgo.

Esta aproximación progresiva permite cumplir con la Norma Técnica sin generar cargas desproporcionadas en el corto plazo, garantizando al mismo tiempo que cada órgano avance hacia un modelo de gestión integral, mediante el desarrollo posterior de los instrumentos operativos que den forma a cada función.

3.6.1. Función de Identificación

Corresponde a las actividades y procesos desarrollados por un OAE para la identificación y adecuada administración de los riesgos de seguridad de información y ciberseguridad asociados a cada uno de los procesos, personas y plataformas electrónicas que sustentan sus procedimientos administrativos.

Esta función comprende las categorías de contexto o entorno del órgano de la Administración del Estado; gobernanza; gestión de activos de información; gestión de riesgos; y contratación y gestión de la relación con proveedores de servicios en la nube. El análisis y operatividad de estas categorías se describirán en la o las guías técnicas a las que hace referencia el artículo 12 de la presente norma.

3.6.2. Función de Protección

Los órganos de la Administración del Estado deberán desarrollar e implementar procesos y actividades destinadas a garantizar las medidas de seguridad que favorezcan la entrega de sus servicios en forma adecuada, oportuna y segura a sus destinatarios.

Esta función implica las categorías de gestión de servidores, redes, autenticación y control de acceso a plataformas electrónicas de los órganos de la Administración del Estado; la concienciación y formación de los funcionarios de la Administración; la seguridad de los datos; los procesos para proteger la información que obra en poder de la Administración; y el registro de eventos; todas las cuales serán definidas y determinadas en la o las guías técnicas a la que alude el artículo 12 de la presente norma técnica.

3.6.3. Función de Detección

Los órganos de la Administración del Estado deberán desarrollar e implementar los procesos y líneas de acción necesarios para la detección oportuna de la ocurrencia de incidentes de seguridad.

Esta función incluye las categorías de análisis de eventos con el objeto de identificar posibles anomalías, fallas o eventos precursores que pudieran derivar en un incidente de seguridad; un monitoreo continuo de la seguridad, en el cual los servidores y sus plataformas electrónicas deben contar con medidas adecuadas para la protección contra código malicioso; y establecer un proceso de detección de dichos eventos. Los detalles operativos de esta función y sus categorías se describirán en la o las guías técnicas conforme a lo dispuesto en el artículo 12 de la presente norma técnica.

3.6.4. Función de Respuesta

Los órganos de la Administración del Estado deberán desarrollar e implementar aquellos procesos y actividades necesarias para adoptar medidas técnicas y organizativas cuando se detecte un incidente de seguridad de la información y/o ciberseguridad.

Esta función contiene las categorías de planificación de respuesta ante incidentes; comunicación de acciones de respuesta; análisis de incidentes; mitigación de incidentes; y mejoras a la planificación y procesos de respuesta. Los procesos, planes, gestiones y análisis asociados a esta función se describirán y desarrollarán en la o las guías técnicas a que se refiere el artículo 12 de esta norma técnica.

3.6.5. Función de Recuperación

Los OAEs deberán desarrollar e implementar los procesos y acciones necesarios para mantener los planes de recuperación y restablecer cualquier capacidad, plataforma electrónica, sistema electrónico, servidor, red o servicio en general, que se haya visto afectado debido a un incidente de seguridad de la información y/o ciberseguridad.

Esta función contiene las categorías de planificación de la recuperación; mejoras a la planificación y procesos de recuperación; y comunicación del estado de recuperación; todas las cuales serán descritas en detalle en la o las guías técnicas a que se refiere el artículo 12 de la presente norma técnica.

Revisión y actualización de la Guía

La presente guía deberá ser revisada, al menos, cada año a fin de determinar si requiere o no de actualización. Las actualizaciones de esta guía deberán tomar en consideración los aprendizajes y las dificultades de aplicación transversales, así como impulsar las buenas prácticas y minimizar las incorrectas que se pudieren haber presentado.

Se deberá dejar registro de todas las versiones y adecuaciones que se le hayan realizado a la presente guía.

Más información

En la Secretaría de Gobierno Digital nos encargamos de apoyar a los órganos de la Administración del Estado en el uso estratégico de las tecnologías digitales. Para facilitar la implementación de los lineamientos en materia de Transformación Digital, ponemos a disposición de las instituciones [documentos y guías](#) , disponibles para descarga desde nuestro sitio web institucional.

Para resolver las preguntas técnicas que tengas sobre el contenido de esta guía, puedes ingresar un ticket a través de la [Mesa de Ayuda](#) . Estaremos atentos para responder todas tus dudas y requerimientos.